

執行階段安全性深入分析

來源：<https://codelabs.developers.google.com/runtime-security-insights?hl=zh-tw>

步驟數：8

將應用程式部署至 Cloud Run 和 GKE 叢集，並查看 Software Delivery Shield Security 部署作業的安全性深入分析資訊

目錄

1. [1. 簡介](#)
2. [2. 設定和需求](#)
3. [3. 準備應用程式](#)
4. [4. 部署 Cloud Run 應用程式](#)
5. [5. Artifact Registry 和 Cloud Build 安全性洞察](#)
6. [6. Cloud Run 安全性深入分析](#)
7. [7. GKE 安全防護機制](#)
8. [8. 恭喜！](#)

步驟 1 · 約 0 分鐘

1. 簡介

在本實驗室中，您將應用程式部署至 Cloud Run 和 GKE 叢集，並在 Software Delivery Shield 安全性深入分析面板中，查看部署作業的安全性深入分析資訊。

課程內容

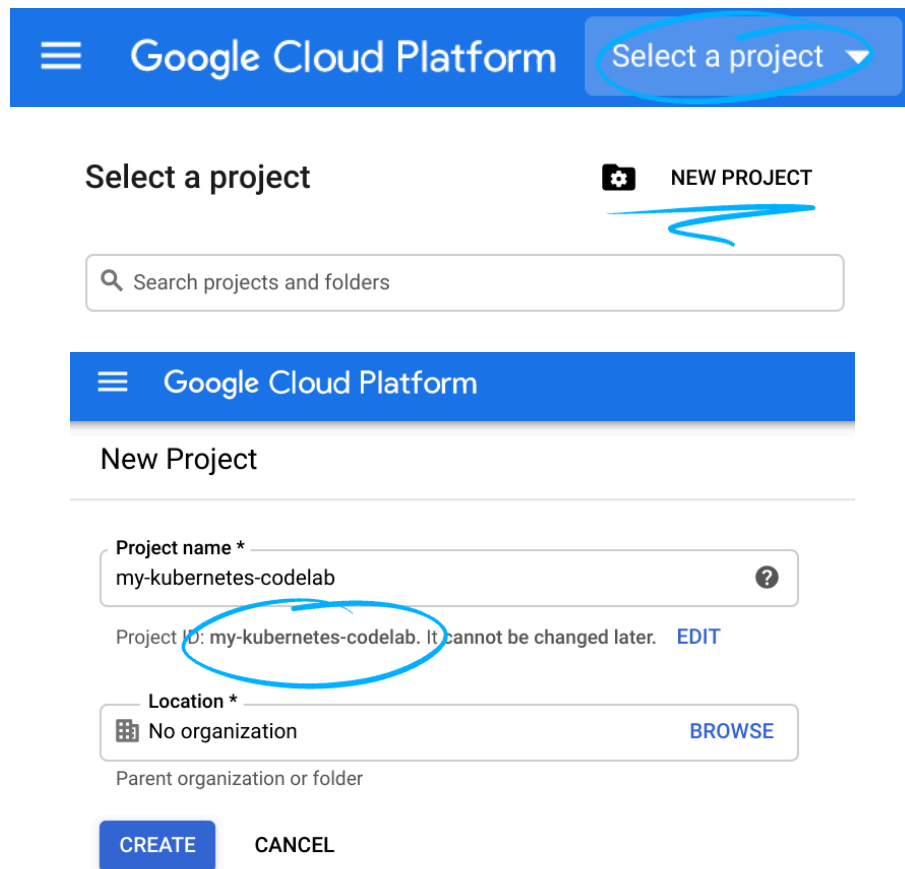
- Artifact Registry 安全性深入分析
 - Cloud Run 安全性深入分析
 - GKE 安全防護機制
-

步驟 2 · 約 0 分鐘

2. 設定和需求

設定 Cloud 專案

1. 登入 [Google Cloud 控制台](#)，然後建立新專案或重複使用現有專案。如果沒有 Gmail 或 Google Workspace 帳戶，請先[建立帳戶](#)。



- **專案名稱**是這個專案參與者的顯示名稱。這是 Google API 未使用的字元字串。你隨時可以更新該位置資訊。
- **專案 ID** 在所有 Google Cloud 專案中都是不重複的，而且設定後即無法變更。Cloud 控制台會自動產生不重複的字串，通常您不需要在意這個字串。在大多數程式碼研究室中，您需要參照專案 ID (通常會標示為 `PROJECT_ID`)。如果您不喜歡產生的 ID，可以產生另一個隨機 ID。你也可以嘗試使用自己的名稱，看看是否可用。完成這個步驟後就無法變更，且專案期間都會維持這個設定。
- 請注意，部分 API 會使用第三個值，也就是「專案編號」。如要進一步瞭解這三種值，請參閱[說明文件](#)。

注意：專案 ID 在全域中是專屬 ID，選定後就無法變更，且其他使用者無法使用。您是該 ID 的唯一使用者。即使刪除專案，該 ID 也無法再使用。

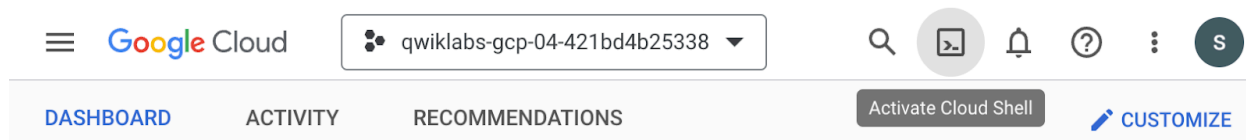
注意：如果您使用 Gmail 帳戶，可以將預設位置設為「沒有機構」。如果您使用 Google Workspace 帳戶，請選擇適合貴機構的位置。

2. 接著，您需要在 Cloud 控制台中[啟用帳單](#)，才能使用 Cloud 資源/API。完成本程式碼研究室的費用應該不高，甚至完全免費。如要關閉資源，避免產生本教學課程以外的費用，您可以刪除自己建立的資源，或刪除整個專案。Google

Cloud 新使用者可參加[價值\\$300 美元的免費試用計畫](#)。

環境設定

按一下搜尋列右側的圖示，啟用 Cloud Shell。



在 Cloud Shell 中，啟用本實驗室所需的 API：

〇〇〇〇

```
gcloud services enable run.googleapis.com \
  cloudbuild.googleapis.com \
  artifactregistry.googleapis.com \
  container.googleapis.com \
  containersecurity.googleapis.com
```

如果系統提示您授權，請點選「授權」繼續操作。

Authorize Cloud Shell

gcloud is requesting your credentials to make a GCP API call.

Click to authorize this and future calls that require your credentials.

REJECT

AUTHORIZE

這時應該會顯示類似以下的成功訊息：

```
Operation "operations/acf.p2-327036483151-73d90d00-47ee-447a-b600-a6badf0eceae"
finished successfully.
```

執行指令，以非同步方式建立 GKE 叢集。實驗室的後續步驟會用到這個名稱：

```
gcloud beta container clusters create gke-cluster \
  --zone us-central1-a \
  --async
```

步驟 3 · 約 0 分鐘

3. 準備應用程式

首先，您將準備一個以 Express 為基礎的簡易型 Node.js 應用程式，用於回應 HTTP 要求。

在 Cloud Shell 建立名為 `starter-nodejs` 的新目錄，然後前往該目錄：

```
mkdir starter-nodejs
cd starter-nodejs
```

執行下列指令，建立 `package.json` 檔案：

```
cat > ./package.json << EOF
{
  "name": "cloudrun-starter-app",
  "version": "1.0.0",
  "description": "Node.js Starter Application",
  "main": "index.js",
  "scripts": {
    "start": "node index.js"
  },
  "author": "",
  "license": "Apache-2.0",
  "dependencies": {
    "express": "^4.18.2"
  }
}
EOF
```

上述檔案包含 `start` 指令碼指令，以及 Express 網頁應用程式架構的依附元件。

接著，在同一個目錄中執行下列指令，建立 `index.js` 檔案：

```
cat > ./index.js << EOF
const express = require('express');
const app = express();

app.get('/', (req, res) => {
  console.log('Received a request.');
```

```
    res.send("Hello Cloud Run!");
});

const port = process.env.PORT || 8080;

app.listen(port, () => {
  console.log('Listening on port', port);
});
EOF
```

這段程式碼會建立基本的網路伺服器，用於監聽 PORT 環境變數定義的通訊埠。應用程式現已就緒，您可以開始將應用程式容器化並部署。

步驟 4 · 約 0 分鐘

4. 部署 Cloud Run 應用程式

執行下列指令來部署應用程式：

```
gcloud run deploy starter-app \  
  --source . \  
  --region us-central1 \  
  --allow-unauthenticated \  
  --max-instances=3
```

確認 Artifact Registry 存放區建立作業：

```
Deploying from source requires an Artifact Registry Docker repository to store built  
containers. A repository named [cloud-run-source-deploy] in region [us-central1] will  
be created.
```

```
Do you want to continue (Y/n)? y
```

5. Artifact Registry 和 Cloud Build 安全性洞察

建構作業會在幾分鐘內完成。

開啟 [Cloud Build](#)，查看最新建構作業的建構成果。

Google Cloud 控制台中的 Cloud Build 使用者介面包含 Software Delivery Shield 安全洞察面板，可顯示與建構作業相關的安全資訊，例如 SLSA 層級、依附元件中的任何安全漏洞，以及建構作業來源資訊。

Google Cloud

qwiklabs-gcp-01-3dffc6823fa3

cloud build

Search

S

Build details

REBUILD

COPY URL

LEARN

Successful: a67b7dbe

Started on Mar 1, 2023, 3:06:41 PM

Source

gs://qwiklabs-gcp-01-3dffc6823fa3_cloudbuild/source/1677701197.95154-01ef2b452be64e15a9f8c0f3ab80a395.tgz

Steps

Duration

BUILD LOG

EXECUTION DETAILS

BUILD ARTIFACTS

Build Summary

1 Step

0: gcr.io/k8s-scaffold/pack

00:01:18

00:00:49

pack build us-central1-dock...

Filter

Enter property name or value

Artifact Name

Type

Security Insights

gs://791293490438.cloudbuild-logs.googleusercontent.com/log-a67b7dbe...

Build log

us-central1-docker.pkg.dev/qwiklabs-gcp-01-3dffc6823fa3/cloud-run-sourc...

Image

us-central1-docker.pkg.dev/qwiklabs-gcp-01-3dffc6823fa3/cloud-run-sourc...

Image

VIEW

查看所建立容器映像檔的安全性洞察資料。按一下掃描構件的連結，即可在 Artifact Registry 中查看這個映像檔的安全漏洞詳細資料。

返回 Cloud Shell 控制台，確認 Cloud Run 應用程式部署作業已完成。

Done.

Service [starter-app] revision [starter-app-00001-maw] has been deployed and is serving 100 percent of traffic.

Service URL: <https://starter-app-nin5jpgefq-uc.a.run.app>

6. Cloud Run 安全性深入分析

Cloud Run 包含安全面板 (搶先版)，可顯示軟體供應鏈安全洞察資訊，例如 SLSA 建構層級合規資訊、建構作業來源資訊，以及執行中服務中發現的安全漏洞。

開啟 [Cloud Run](#)，然後查看「REVISIONS」(修訂版本) 或「SECURITY」(安全性) 分頁下方的「Security Insights」(安全性深入分析)。

The screenshot shows the Google Cloud Run console interface. The top navigation bar includes the Google Cloud logo, a project selector (qwiklabs-gcp-01-3dffc6823fa3), a search bar, and various utility icons. The main content area is divided into two panels. The left panel, titled 'Revisions', shows a table of revisions for the 'starter-app'. The right panel, titled 'SECURITY', provides detailed security insights for the selected revision 'starter-app-00001-rug'. This panel includes sections for 'Identity & Encryption', 'Software Delivery Shield' (marked as a preview), and 'Vulnerabilities'. The 'Vulnerabilities' section displays a bar chart showing the count of issues by severity: 0 Critical, 0 High, 14 Medium, and 15 Low. The 'Artifacts scanned' link points to the 'starter-app'.

Name	Traffic	Deployed	Rev	Actions
starter-app-00001-rug	100% (to latest)	10 minutes ago	+	⋮

SECURITY

Identity & Encryption

Service account: [791293490438-compute@developer.gserviceaccount.com](#)

Encryption Key: Google-managed

Software Delivery Shield PREVIEW

Software Delivery Shield is a new solution to safeguard artifact integrity across your entire software delivery lifecycle. [Learn more](#) about how it can prevent tampering, improve integrity, and secure packages and infrastructure.

Artifact (starter-app)
SLSA Build Level 3 [What's this?](#)

Vulnerabilities

Critical	High	Medium	Low
0	0	14	15

Artifacts scanned: [starter-app](#)

這個面板會顯示下列資訊：

- **身分和加密**：預設 Compute Engine 服務帳戶的電子郵件地址，以及用於部署作業的加密金鑰。
- **SLSA 等級**：這個建構作業的 SLSA 等級為 3，可根據 SLSA 規格判斷軟體建構程序的成熟度
- **安全漏洞**：應用程式依附元件中發現的任何安全漏洞。
- **建構作業詳細資料**：建構作業詳細資料，例如建構工具和記錄檢視連結。
- **建構作業來源資訊**：建構作業來源資訊，也就是建構的可驗證中繼資料集合。包括建構的映像檔摘要、輸入來源位置、建構工具鍊、建構步驟和建構時長等詳細資料。

步驟 7 · 約 0 分鐘

7. GKE 安全防護機制

GKE 可以評估容器資安態勢，並針對叢集設定、工作負載設定和安全漏洞提供主動式指引。其中包括資安態勢資訊主頁(搶先版)，可掃描 GKE 叢集和工作負載，為您提供具體可行的建議，藉此提升資安態勢。

在接下來的步驟中，您會將應用程式部署至 GKE 叢集，並在 GKE 資安態勢資訊主頁中查看安全性深入分析資訊。

執行下列指令，確認叢集已準備就緒：

```
gcloud beta container clusters list
```

輸出內容範例：

```
NAME: gke-cluster
LOCATION: us-central1-a
MASTER_VERSION: 1.24.9-gke.3200
MASTER_IP: 34.29.226.228
MACHINE_TYPE: e2-medium
NODE_VERSION: 1.24.9-gke.3200
NUM_NODES: 3
STATUS: RUNNING
```

取得 GKE 叢集的憑證和設定：

```
gcloud container clusters get-credentials gke-cluster \
  --region=us-central1-a
```

執行指令，使用上一步建構的映像檔部署應用程式：

```
export PROJECT_ID=$(gcloud config get-value project)

kubectl run starter-app \
  --image us-central1-docker.pkg.dev/${PROJECT_ID}/cloud-run-source-deploy/starter-app:latest \
  --port 8080
```

GKE 工作負載應盡量採用強化設定，以限制攻擊面。手動檢查叢集中的工作負載是否有設定問題，在規模較大的情況下可能很困難。您可以使用資安態勢資訊主頁，自動掃描多個叢集中的所有執行中工作負載設定，並取得可執行的評分結果和具體建議，藉此提升資安態勢。

啟用工作負載設定掃描：

```
gcloud beta container clusters update gke-cluster \
  --region=us-central1-a \
  --enable-workload-config-audit
```

除了掃描工作負載設定，您也可以啟用工作負載安全漏洞掃描，並在資安態勢資訊主頁中查看結果。這組功能會提供具體資訊和建議，協助您提升 GKE 叢集和工作負載的安全性。

GKE 會使用公開 CVE 資料庫 (例如 [NIST](#)) 的安全漏洞資料，自動掃描 GKE 叢集中每個符合資格的 Pod 內容器映像檔，找出已知安全漏洞。

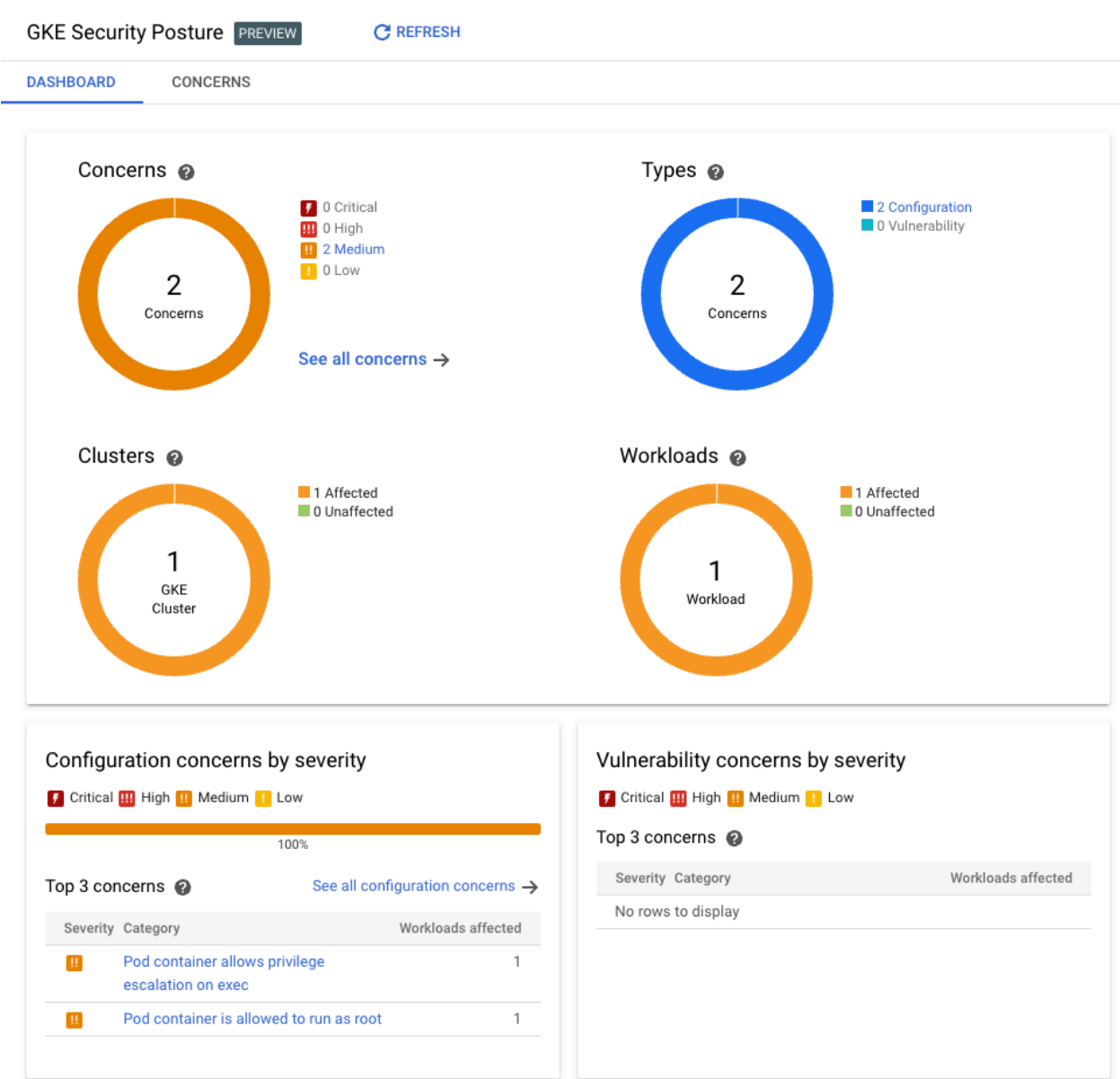
如果系統在容器映像檔中發現安全漏洞，GKE 會指派嚴重程度評分，並在 Google Cloud 控制台的資安態勢資訊主頁中顯示結果。GKE 也會將項目新增至 Cloud Logging，以供稽核和追蹤。

啟用工作負載安全漏洞掃描：

```
gcloud beta container clusters update gke-cluster \
  --region=us-central1-a \
  --enable-workload-vulnerability-scanning \
  --async
```

開啟 GKE「安全防護機制」頁面。

請稍候幾分鐘，等待工作負載稽核完成，然後查看結果。



!! Medium: Pod container is allowed to run as root

DETAILS

AFFECTED WORKLOADS

Description

A container has been explicitly allowed to run as the root user if the `runAsUser` or the `USER` directive in the image specifies the root user. The lack of preventive security controls when running as the root user increases the risk of container escape.

Recommended action

Apply the following steps to: [affected workloads](#).

▶ Via command line

1. Open the YAML for an affected workload.
2. Set the following restricted fields to one of the allowed values:

▼ [SHOW RESTRICTED FIELDS](#)

使用資安態勢資訊主頁的原因

資安態勢資訊主頁是基礎安全措施，適用於任何符合資格的 GKE 叢集。Google Cloud 建議您在所有叢集中使用資安態勢資訊主頁，原因如下：

- 干擾程度極低：功能不會干擾或中斷正在執行的工作負載。
- 可做為行動依據的建議：如果發現問題，資安態勢資訊主頁會提供操作項目，協助您解決問題。這些動作包括可執行的指令、可進行的設定變更範例，以及如何降低安全漏洞風險的建議。
- 視覺化：資安態勢資訊主頁會以高階視覺化方式呈現影響專案叢集的疑慮，並提供圖表，顯示您取得的進展和各項疑慮的潛在影響。
- 意見導向的結果：GKE 會根據 Google 安全團隊的專業知識和業界標準，為發現的問題指派嚴重程度評分。
- 可稽核的事件記錄：GKE 會將所有發現的問題新增至 Logging，以利產生報表及進行監控。

步驟 8 · 約 0 分鐘

8. 恭喜！

恭喜！您已完成程式碼研究室。

涵蓋內容：

- 建構構件和在 Cloud Run 和 GKE 上執行的應用程式的安全性洞察資訊

清除所用資源

如要避免系統向您的 Google Cloud 帳戶收取本教學課程所用資源的費用，請刪除含有相關資源的專案，或者保留專案但刪除個別資源。

刪除專案

如要避免付費，最簡單的方法就是刪除您為了本教學課程所建立的專案。

—

上次更新時間：2023 年 3 月 21 日
